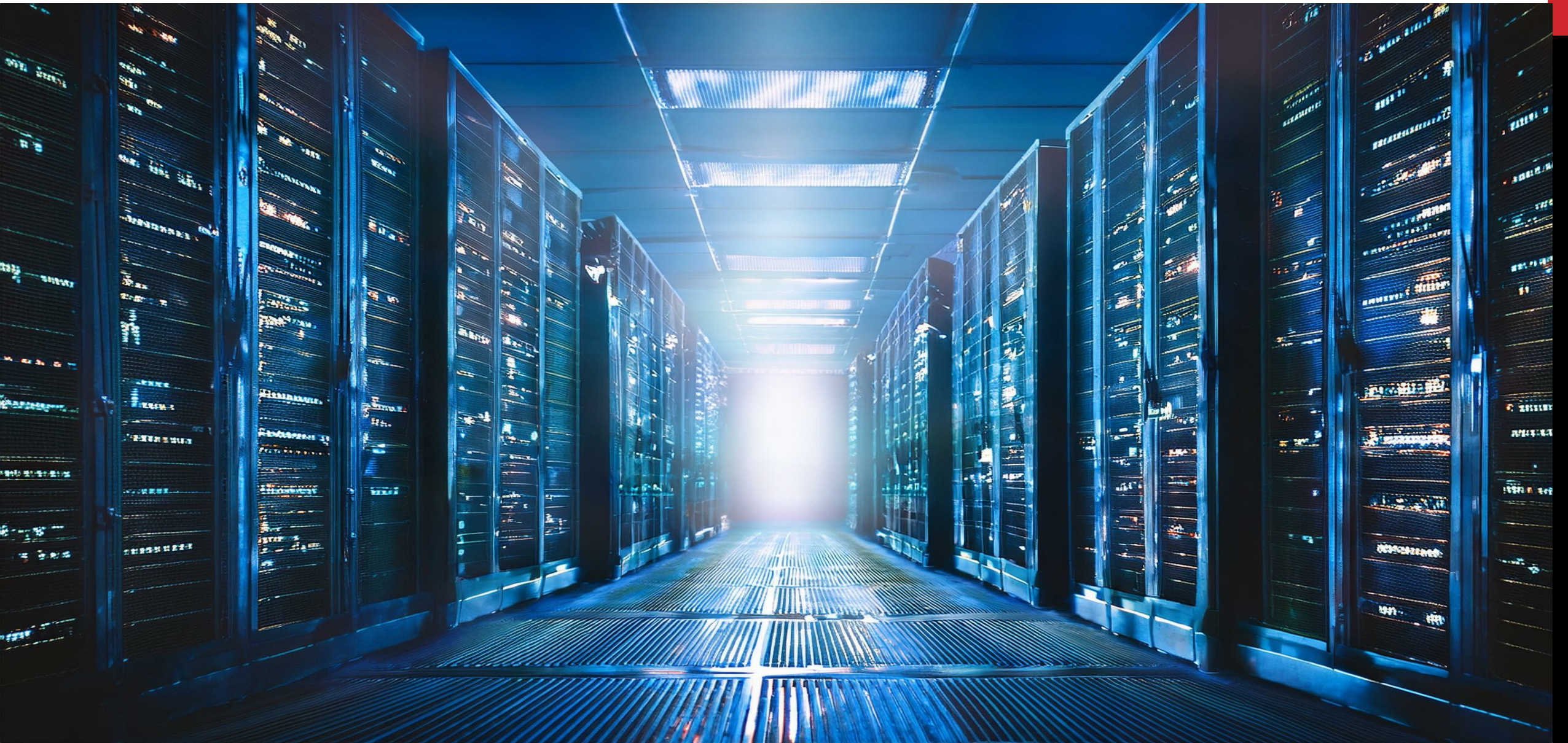


NETWORKING FUNDAMENTALS IV





COURSE STRUCTURE

Day 1: Networking Fundamentals I

Day 2: Networking Fundamentals II

Day 3: Networking Fundamentals III

Day 4: Network Security in Depth

Day 5: Network Management & Automation

AGENDA FOR DAY 4

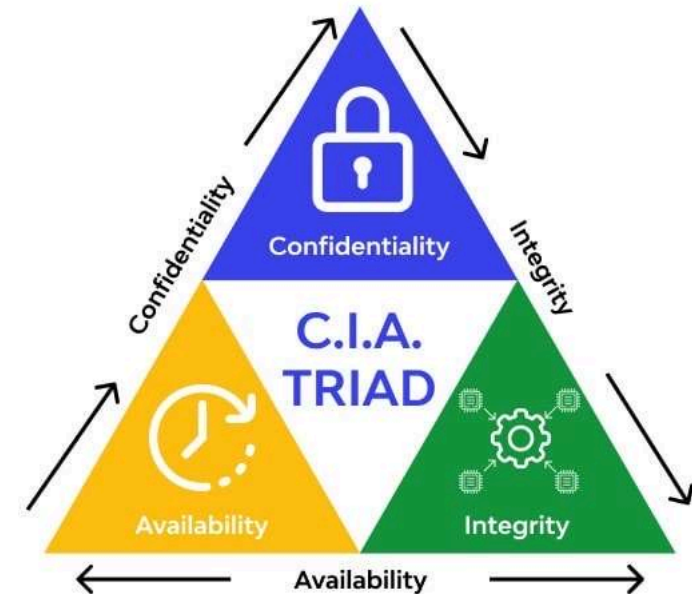
1. Network Threat Landscape
2. Layer 2 & Layer 3 Attack Types
3. L2 Defense Mechanisms — DHCP Snooping, DAI, Port Security
4. Firewalls in Depth & DMZ Design
5. VPN Types — Site-to-Site vs Remote Access, IPSec vs SSL/TLS
6. Zero Trust Networking
7. Knowledge Checks & Labs



NETWORK SECURITY

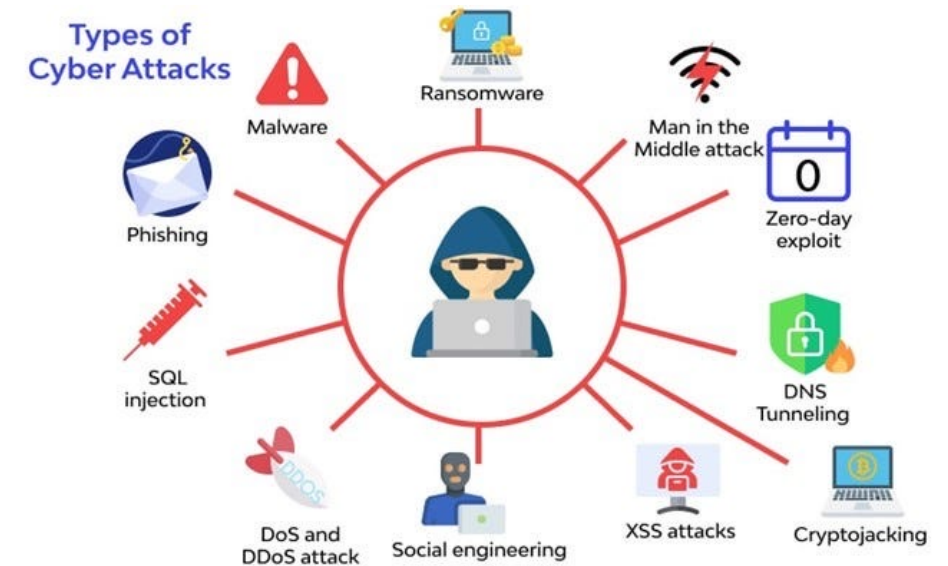
THE CIA TRIAD — SECURITY FOUNDATIONS

- **Confidentiality:** data accessible only to authorised users; enforced via encryption, ACLs, and access control
- **Integrity:** data cannot be modified without detection; enforced via hashing (MD5/SHA), digital signatures, certificates
- **Availability:** systems and data accessible when needed; enforced via redundancy, failover, DDoS mitigation, backups
- **Authentication:** prove who you are (passwords, MFA, certificates, biometrics)
- **Authorization:** what you are allowed to do once authenticated (RBAC, ACLs, privilege levels)
- **Non-repudiation:** you cannot deny an action you took; audit logs, digital signatures
- **Defence-in-depth:** no single control is sufficient — layer physical, network, host, application, and data controls



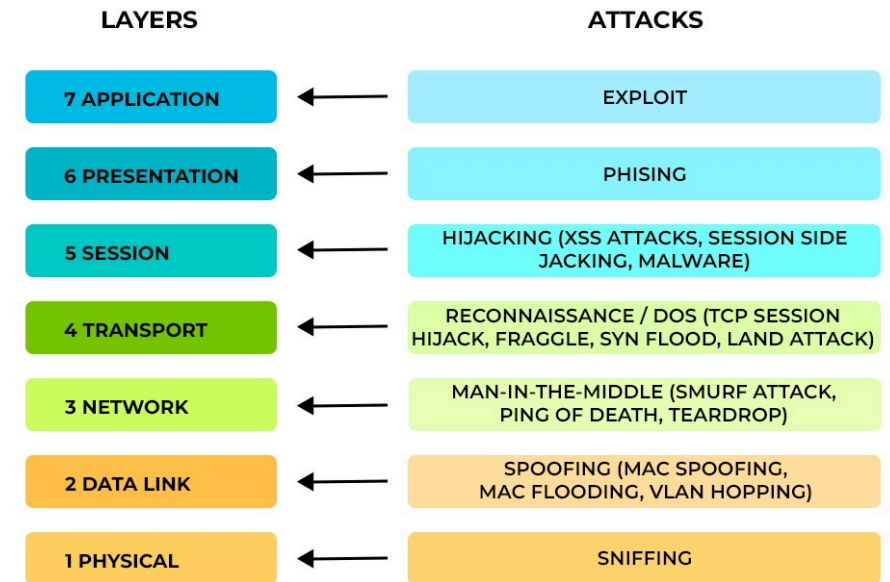
NETWORK THREAT LANDSCAPE

- **Reconnaissance:** passive (OSINT, DNS enumeration) and active (port scanning, ping sweeps) information gathering
- **Man-in-the-Middle** (MITM): attacker silently intercepts and optionally modifies traffic between two parties
- **Denial of Service** (DoS) / DDoS: overwhelm a target with traffic or requests to make it unavailable
- **Phishing & Social Engineering:** trick users into revealing credentials or executing malware
- **Insider Threats:** malicious or negligent employees with legitimate access cause the most costly breaches
- **Malware categories:** virus (needs host file), worm (self-propagating), ransomware (encrypts and extorts), rootkit (hides itself), spyware
- **Zero-day exploit:** vulnerability unknown to the vendor, no patch available; often sold on dark web



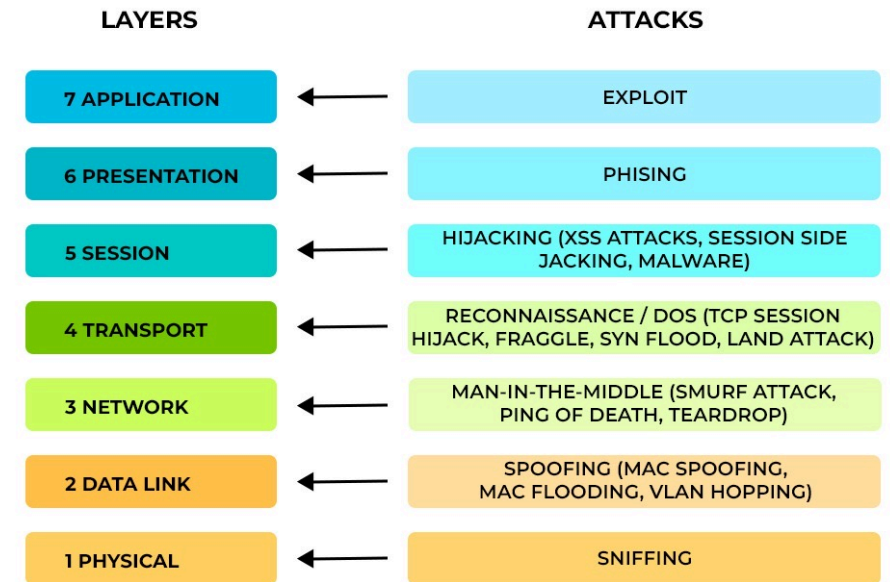
LAYER 2 ATTACK TYPES

- **MAC Flooding:** attacker sends thousands of forged MACs to fill the CAM table; switch fails open and broadcasts all frames (hub mode)
- **ARP Spoofing/ Poisoning:** attacker sends gratuitous ARP replies claiming their MAC owns a legitimate IP; enables MITM
- **VLAN Hopping** (Switch Spoofing): attacker's device pretends to be a switch and negotiates a trunk; gains access to all VLANs
- **VLAN Hopping** (Double Tagging): attacker sends 802.1Q frame with two tags; outer tag stripped at first switch, inner tag routes frame to victim VLAN
- **STP Attack:** attacker sends superior BPDUs to become root bridge; all traffic flows through attacker's device
- **CDP/LLDP Reconnaissance:** protocols leak device model, IOS version, IP — disable on untrusted ports with no cdp enable
- **Countermeasure principle:** never trust frames arriving on access ports; validate everything at the edge



LAYER 3 & ABOVE ATTACK TYPES

- **IP Spoofing:** attacker forges source IP address; used in DDoS amplification attacks and to bypass IP-based ACLs
- **ICMP Attacks:** ping floods, Smurf attack (broadcast amplification), ICMP redirect attacks to reroute traffic
- **DNS Poisoning / Cache Poisoning:** corrupt DNS resolver cache; users directed to attacker-controlled servers
- **BGP Hijacking:** malicious AS advertises more-specific routes to attract traffic destined for other organizations
- **TCP SYN Flood:** attacker sends flood of SYN packets without completing handshakes; exhausts server connection table
- **Session Hijacking:** attacker predicts or steals TCP sequence numbers to inject data into an established session
- **Amplification attacks:** DNS, NTP, SSDP — attacker sends small spoofed request to open server; large response sent to victim



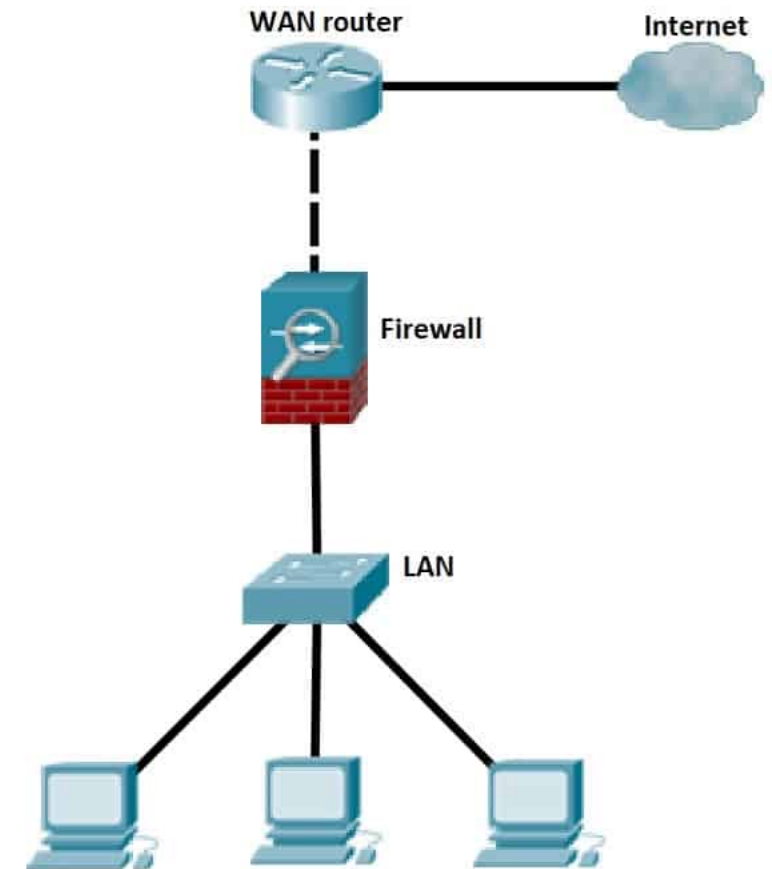
L2 DEFENCE MECHANISMS

- **Port Security:** max MACs per port; violation = restrict / protect / shutdown
 - `switchport port-security maximum 2`
- **DHCP Snooping:** only trusted uplink ports can send DHCP offers; drops rogue servers
 - `ip dhcp snooping vlan 10 / ip dhcp snooping trust`
- **Dynamic ARP Inspection:** validates ARP against snooping table; drops spoofed replies
 - `ip arp inspection vlan 10`
- **IP Source Guard:** validates source IP per frame; drops spoofed IPs
- **BPDU Guard:** err-disables port if BPDU received on PortFast port



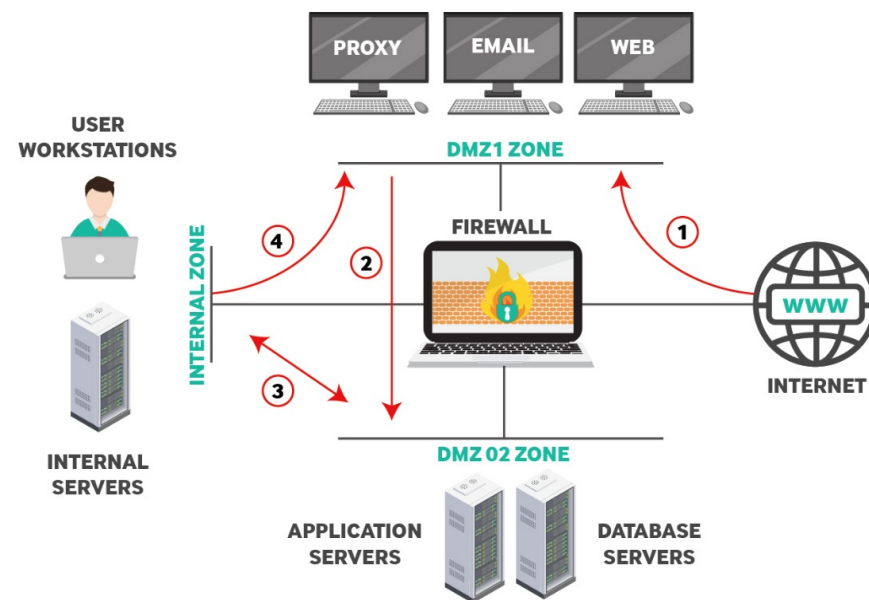
FIREWALLS IN DEPTH

- **Packet filter (stateless):** matches rules on src/dst IP, port, protocol per packet; no connection tracking; fast but limited
- **Stateful firewall:** tracks connection state table; permits return traffic automatically; default for perimeter firewalls
- **Application-layer / proxy firewall:** deep inspection of application data; understands HTTP, DNS, FTP semantics; can strip malicious payloads
- **Next-Generation Firewall (NGFW):** combines stateful + IDS/IPS + application identification + URL filtering + SSL inspection + user identity
- **IDS vs IPS:** IDS detects and alerts (passive), IPS detects and blocks inline (active) — IPS adds latency but stops threats
- **WAF (Web Application Firewall):** NGFW specialized for HTTP/HTTPS; protects against SQLi, XSS, CSRF at the application layer
- **Firewall placement:** internet edge (perimeter), data center edge, east-west (micro-segmentation between workloads)



DMZ DESIGN & NETWORK SEGMENTATION

- **DMZ (De-Militarized Zone)** — isolated network segment between the internet and the internal LAN
- **Classic three-legged firewall:** Outside (internet) | Firewall | DMZ | Firewall | Inside (LAN)
- **Public-facing servers (web, mail, DNS) sit in the DMZ:** compromising them does not give access to internal systems
- **Traffic flows:** Internet --> DMZ (permitted) | Internet --> LAN (blocked) | LAN --> DMZ (permitted) | LAN --> Internet (NAT + filtered)
- **Network segmentation beyond DMZ:** separate VLANs for servers, users, printers, IoT, guest Wi-Fi — limits blast radius
- **Micro-segmentation:** east-west firewalls between workloads in the data center; NGFW or software-defined policies
- **Zero Trust principle:** the network perimeter is not a trust boundary — authenticate and authorize every connection



POP QUIZ:

Which attack fills a switch's CAM table with forged MAC addresses, causing it to broadcast frames to all ports?

- A. ARP Spoofing
- B. MAC Flooding
- C. VLAN Hopping
- D. STP Attack



POP QUIZ:

Which attack fills a switch's CAM table with forged MAC addresses, causing it to broadcast frames to all ports?

- A. ARP Spoofing
- B. **MAC Flooding**
- C. VLAN Hopping
- D. STP Attack



POP QUIZ:

Which Layer 2 defence validates ARP messages against a DHCP snooping binding table and drops unauthorised ARP replies?

- A. IP Source Guard
- B. Port Security
- C. Dynamic ARP Inspection
- D. BPDU Guard



POP QUIZ:

Which Layer 2 defence validates ARP messages against a DHCP snooping binding table and drops unauthorised ARP replies?

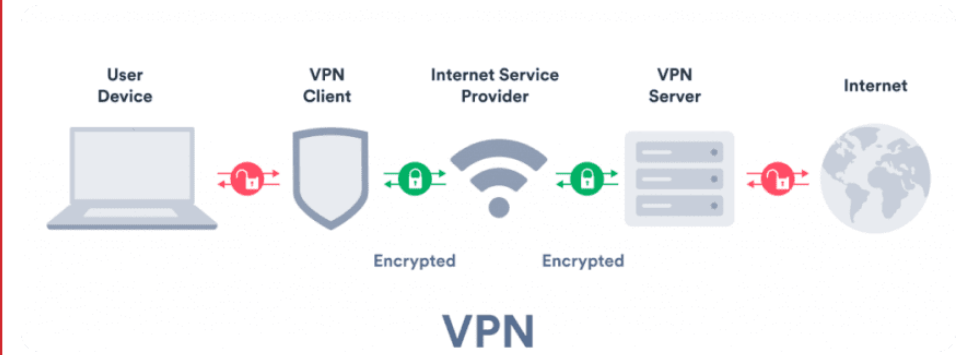
- A. IP Source Guard
- B. Port Security
- C. **Dynamic ARP Inspection**
- D. BPDU Guard



VPN TYPES & TUNNELING

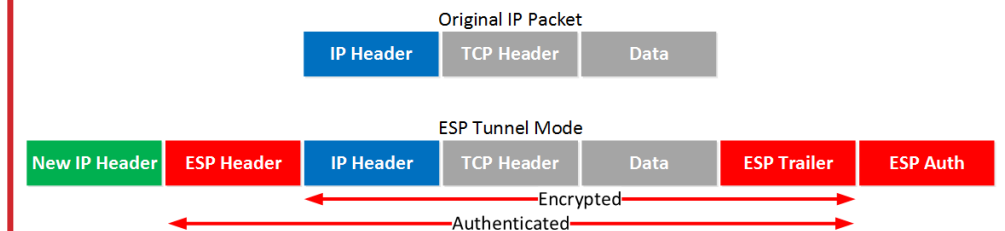
VPN FUNDAMENTALS

- **VPN (Virtual Private Network):** encrypts traffic over an untrusted network (internet) to create a private tunnel
- **Site-to-site VPN:** permanent encrypted tunnel between two fixed locations (headquarters to branch office)
 - Both endpoints have a VPN gateway; end devices are unaware of the tunnel
- **Remote access VPN:** individual users connect from anywhere to the corporate network using a VPN client
- **SSL/TLS VPN (e.g. Cisco AnyConnect):** works over HTTPS port 443, firewall-friendly, browser or client-based
- **IPSec VPN (IKEv1/IKEv2):** stronger but requires client software, UDP 500/4500 — may be blocked by some firewalls
- **Split tunnelling:** only corporate-destined traffic goes through the VPN; direct internet traffic exits locally — reduces load but lowers security

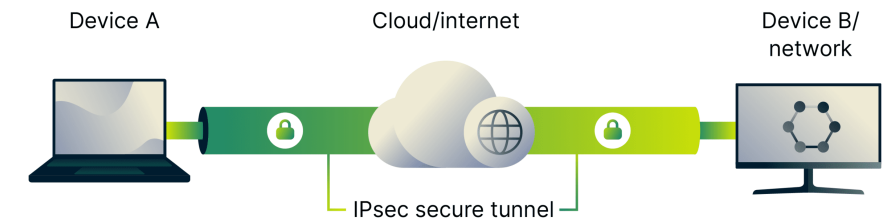


IPSEC — INTERNET PROTOCOL SECURITY

- **IPSec operates at Layer 3:** transparent to applications; encrypts entire IP payload
- **Two modes:** Transport mode (encrypts payload only, headers visible) | Tunnel mode (encrypts entire original packet, new headers added)
- **AH (Authentication Header):** provides integrity and anti-replay; does NOT encrypt; rarely used alone
- **ESP (Encapsulating Security Payload):** provides encryption + integrity + anti-replay; most common
- **IKE (Internet Key Exchange):** negotiates security associations (SAs); IKEv2 is modern standard
- **Phase 1 (IKE SA):** authenticate peers, agree on encryption (AES) and hash (SHA) algorithms, establish secure channel
- **Phase 2 (IPSec SA):** negotiate data encryption keys using Phase 1 channel, establish the actual VPN tunnel
- `show crypto isakmp sa` / `show crypto ipsec sa`: verify tunnel status



What is IPsec?



ZERO TRUST NETWORKING

- **Traditional model:** trust inside the perimeter — once on the LAN, broad access granted; insider threat catastrophic
- **Zero Trust principle:** never trust, always verify — every connection requires authentication and authorization
- **Core pillars:** verify identity (MFA, certificates) | validate device health (EDR, patch level) | least-privilege access | assume breach
- **Micro-segmentation:** even internal east-west traffic is authenticated and policy-controlled — limits lateral movement
- **Software-Defined Perimeter (SDP) / ZTNA (Zero Trust Network Access):** replaces VPN; user gets access only to specific app, not entire network
- **Identity as the new perimeter:** Active Directory, SSO, SAML/OAuth — who you are matters more than where you are
- **Continuous verification:** trust is not permanent — re-authenticate on behavior change, time-based re-validation

ZERO TRUST SECURITY



POP QUIZ:

Which VPN type creates a permanent encrypted tunnel between two sites without requiring end-user software?

- A. Remote access VPN
- B. Site-to-site VPN
- C. SSL VPN
- D. Split tunnel VPN



POP QUIZ:

Which VPN type creates a permanent encrypted tunnel between two sites without requiring end-user software?

- A. Remote access VPN
- B. **Site-to-site VPN**
- C. SSL VPN
- D. Split tunnel VPN



POP QUIZ:

What is the core principle of Zero Trust networking?

- A. Trust all traffic inside the firewall perimeter
- B. Never trust, always verify — authenticate every connection regardless of location
- C. Use VPN for all remote connections
- D. Encrypt only sensitive data in transit



POP QUIZ:

What is the core principle of Zero Trust networking?

- A. Trust all traffic inside the firewall perimeter
- B. **Never trust, always verify — authenticate every connection regardless of location**
- C. Use VPN for all remote connections
- D. Encrypt only sensitive data in transit



LAB 09: L2 ATTACK & DEFENCE SIMULATION

- Goal: Observe common Layer 2 attacks and configure defences in Packet Tracer
 - Build a small LAN: 1 switch, 4 PCs, 1 router with DHCP
 - Simulate ARP spoofing: observe gratuitous ARP entries in `arp -a`; identify the forged entry
 - Enable DHCP Snooping on VLAN 10 and mark the router uplink as trusted
 - Enable Dynamic ARP Inspection on VLAN 10 — verify spoofed ARP is dropped
 - Configure port security on access ports: maximum 1 MAC, violation shutdown
 - Verify with: `show ip dhcp snooping binding` | `show ip arp inspection statistics` | `show port-security interface`

LAB 10: ACL-BASED FIREWALL RULES & DMZ DESIGN

- Goal: Use extended ACLs to simulate firewall zones across Outside, DMZ, and Inside interfaces
 - Build the topology: 1 router with 3 interfaces, 1 Outside PC, 1 DMZ PC, 2 Inside PCs and a switch
 - Assign IPs: Outside 203.0.113.0/30 | DMZ 10.0.2.0/24 | Inside 10.0.1.0/24
 - Verify baseline: all zones can reach each other before any ACLs are applied
 - Apply ACL 110 inbound on Outside — permit internet→DMZ port 80, deny internet→Inside
 - Apply ACL 111 inbound on DMZ — deny DMZ→Inside to contain a compromised server

LAB 11: STANDARD & EXTENDED ACLS: MULTI-DEPARTMENT ACCESS CONTROL

- Goal: Enforce per-department access policy using standard and extended ACLs across HR, Finance, and Guest subnets
 - Build the topology: 1 router, 3 switches, HR 10.0.10.0/24 | Finance 10.0.20.0/24 | Guest 10.0.30.0/24
 - Assign IPs: Outside 203.0.113.0/30 | DMZ 10.0.2.0/24 | Inside 10.0.1.0/24
 - Verify baseline: every department can reach every other before ACLs are applied
 - Apply standard ACL 10 outbound on Gi0/0 — block Guest from HR; permit everything else
 - Deliberately apply ACL 10 near the source instead — observe it blocks Guest from Finance too; restore correct placement
 - Apply extended ACL 110 inbound on Gi0/1 — permit Finance→HR Server port 80 only; deny all other Finance→HR traffic
 - Apply standard ACL 20 outbound on Gi0/1 — block Guest from Finance
 - Verify with: show access-lists | show ip interface Gi0/0 | show ip interface Gi0/1